The impact of WannaCry on industrial contr



May 13, 2017 Cybersecurity, ICS Security

#CYBERSECURITY #ICS #INDUSTRIAL CONTROL SYSTEMS #MS27-010 #WANNACRY

The impact of WannaCry on industrial control systems (ICS)

IIoT World

HOME OUR TOPICS INDUSTRIES COVERED E

data, Brad Hegrat, IOActive's Director of Advisory Services, explains the impact of WannaCry on industrial control systems (ICS).

A few weeks ago back in mid-March (2017), Microsoft issued a security bulletin (MS17-010) and patch for a vulnerability that was yet to be publicly disclosed or referenced. According to the bulletin, *"the most severe of the vulnerabilities could allow remote code execution if an attacker sends specially crafted messages to a Microsoft Server Message Block 1.0 (SMBv1) server. This security update is rated Critical for all supported releases of Microsoft Windows."* https://technet.microsoft.com/en-us/library/security/ms17-010.aspx

Normally, when Microsoft issues a patch or security there is an acknowledgement on their website regarding the disclosure. Below is the website and it is an interesting process at this point to make a visit – https://technet.microsoft.com/en-us/library/security/mt745121.aspx

Notice anything? MS17-010 is conspicuous in its absence.

It is often said that timing is everything, and in this case, Microsoft beat the clock. Exactly one month later, on 14 April 2017, ShadowBrokers dropped a fifth in a series of leaks supposedly associated with the NSA which included an exploit codenamed ETERNALBLUE. Flashing forward to today almost one full month later, this payload has been weaponized and over the last few hours, has been used in a rash of ransomware attacks throughout the UK, mainland Europe and western Asia.

https://krebsonsecurity.com/2017/05/u-k-hospitals-hit-in-widespread-ransomware-attack/

https://www.forbes.com/sites/thomasbrewster/2017/05/12/nsa-exploit-used-by-wannacry-ransomware-in-global-explosion/

https://www.theregister.co.uk/2017/05/12/spain_ransomware_outbreak/

Considering the timing, one could be inclined to consider that this was not just Microsoft's good fortune.

While pretty much the entire wired world is rushing to patch MS17-010, even though that patch has been out for almost two months, there is one technology area that is cause for particular concern especially when it comes to ransomware. This area of concern are the global industrial environments.

Historically, general purpose, run of the mill malware that leverages SMB and NetBIOS interfaces in the industrial environment are particularly troublesome, with many systems remaining infected many years later. Besides ICS environments being in an operational state that complicates the life of those seeking to patch them, some of these legacy systems often use a protocol called or Object linking and embedding for Process Control (OLE for Process Control, or OPC for short). OPC Classic (a legacy protocol implementation), relies on the Distributed Component Object Model (DCOM) which makes heavy use of the Distributed Computing Environment / Remote Procedure Calls (DCE/RPC) protocol. In addition to NetBIOS and depending on both configuration and implementation, SMB is one of the

Consider the major, well known examples of malware impacting the ICS space. In November of 2008, the first variant of Conficker was publicly identified and due to the ICS requirements of keeping the NetBIOS and SMB ports open, Conficker is still found to this day. Conficker exploited MS08-067 and due to its password brute forcing capability, is incredibly resilient to remediation attempt at the system level. Another major example that utilized the attack vector in MS08-067 was Stuxnet. We all know how that turned out. MS17-010 has the potential to be every bit as damaging, and in some ways much worse.

With the WannaCry/WanaCrypt ransomware in the wild, crossing into industrial control systems would be particularly devastating. Systems requiring real-time interfacing and control influence over physical assets could face safety/critical shutdown, or worse. When thinking about critical services to modern society (power, water, wastewater, etc.), there is a real potential, potentially for the first time ever, where critical services could be suspended due to ransomware. It may be time to rethink critical infrastructure cybersecurity engineering, because if MS17-010 exploiting malware variants are successful, we are clearly doing something wrong.

The article originally appeared on IOActive's blog.

0

PREVIOUS POST NEXT POST



0 Share



0 Share
Sponsored by aDolus



0 Share

An Executive Order from US President Donald Trump in May this year overhauled the backbone of the nation's electricity infrastructure, highlighting gaps and vulnerabilities in the operations of power systems and bulk power equipment, to attacks by hackers, terrorists and

September 8, 2020
Cybersecurity, Energy

Track Sponsored by aDolus This track, originally presented at IIoT World Days on June 30, 2020, covers 4 presentations from industry leaders in ICS Security: Five Blind Men and the Elephant called ICS Supply Chain Security The Road to Industrial IoT Security Automated ICS

September 4, 2020
Augmented Reality, Cybersecurity, ICS Security

Programming

In this White Paper, previously unknown design flaws that malicious actors could exploit to hide malicious functionalities in industrial programming for robots and other automated manufacturing machines are revealed. Since these flaws are difficult to fix, enterprises that deploy vulnerable

September 1, 2020
Cybersecurity, ICS Security

Post a Comment

Your comment

Your Name | Your Email | Website

Save my name, email, and website in this browser for the next time I comment.

I'm not a robot
reCAPTCHA
Privacy - Terms

SUBMIT

Get in touch with us!

Useful pages

About

Contact us

Terms of Use

Privacy Policy

P.O.Box 450624
Cleveland, Ohio 44145
Telephone: +1 949-427-0564

©2017-2020 IIoT World. All articles submitted by our contributors do not constitute the views, endorsements or opinions of IIoT-World.com.